

Networks and Systems Security II

CSE 354/554

Instructor: Sambuddho

(Semester: Winter 2025)

Public Key Infrastructure - SSL/TLS

Public Key Infrastructure (PKI)

- An abstract model that relies on public/private cryptography for ensuring authentication, confidentiality and integrity protection.
- Overall idea and system features:
 - CA: Certifying authority - signs others' public key certificates, verifying their identities (aka Issuer).
 - Verifier: Certificates can be chained, the one that evaluates the chain of certificates is known as the verifier.
 - Certificate: Stores information regarding who is the owner (aka subject), his/her public key, the issuer, the signature (for authentication), other miscellaneous information - validity period, revocation information etc.
 - Trust Anchors: Public key that is chosen as the first trusted public key in a chain of public keys / certificates.

PKI Trust Models

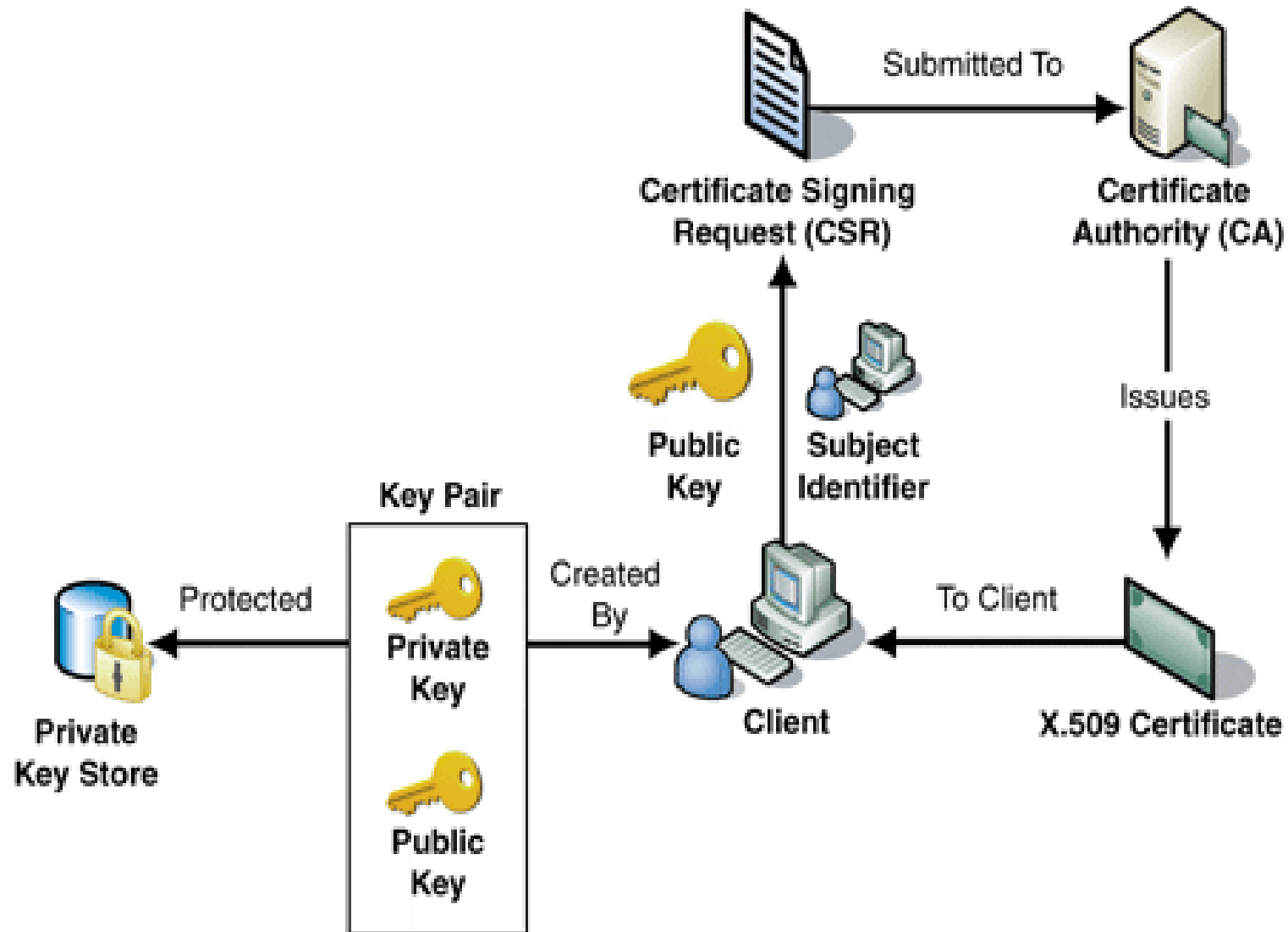
- Monopoly model (single root CA): Universally chosen trusted CA which signs EVERYONE's certificates - naïve model - unscalable, single point of failure..
- Monopoly plus Registration Authorities (RA): CA chooses few different RAs which do the job of the single CA. Advantages - there are several sources to obtain signatures.
- Delegated CAs: Hierarchically aligned CAs from which users can obtain certificates. Difference from RA model - hierarchical vs linear/flat model.
- Oligarchy: List of trust anchors and not merely one. The user can choose and delete individual trust anchors.
- Anarchy: Used in PGP/GPG. Anyone can choose and trust anyone. Two parties can sign each others keys. Most often there isn't any centralized trusted CAs or trust anchors.

X.509 Certificate Format

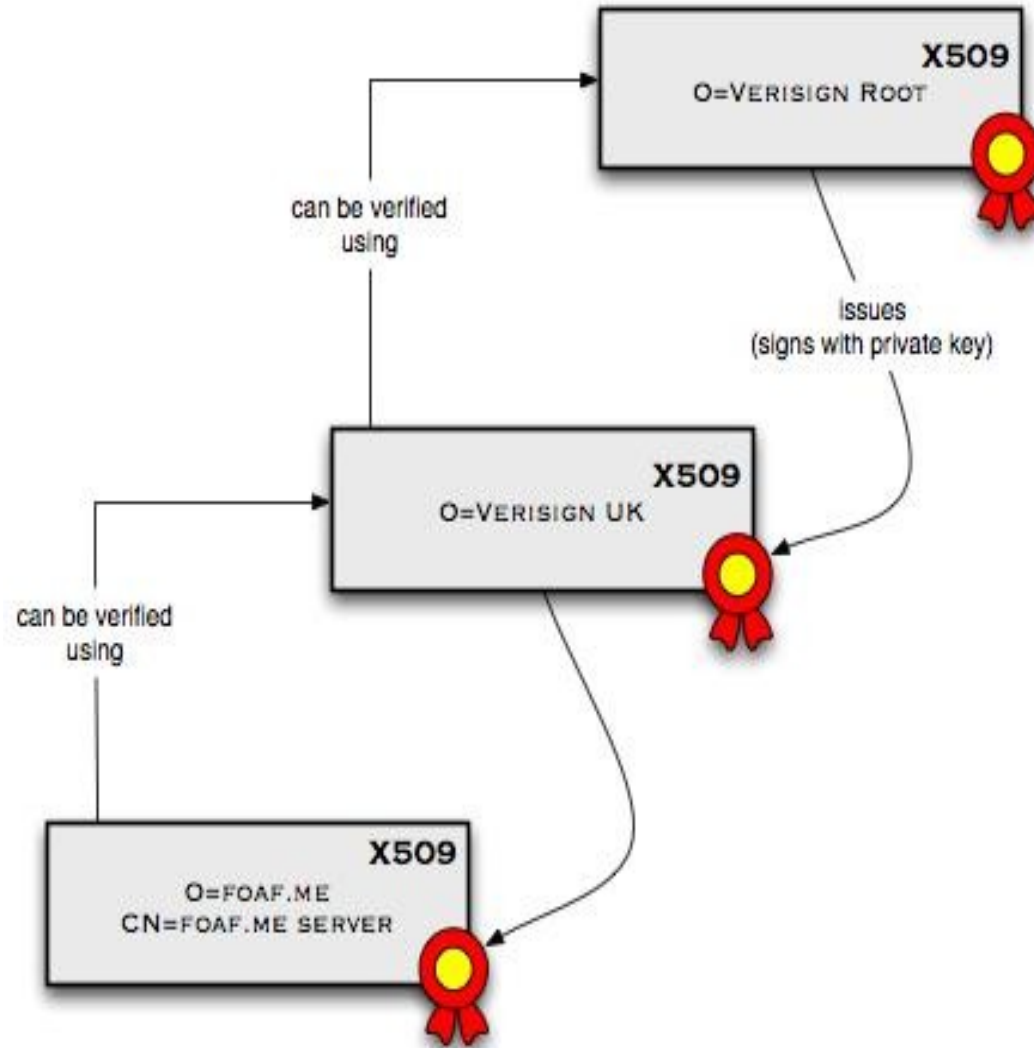
```
X509 Certificate:
Version: 3
Serial Number: 00
Signature Algorithm:
  Algorithm ObjectId: 1.2.840.113549.1.1.4
  Algorithm Parameters:
    05 00
Issuer: E=personal-freemail@thawte.com,
       CN=Thawte Personal Freemail CA,
       OU=Certification Services Division,
       O=Thawte Consulting, L=Cape Town, S=Western Cape, C=ZA
NotBefore: 12/31/1995 4:00 PM
NotAfter: 12/31/2020 3:59 PM
Subject: E=personal-freemail@thawte.com,
        CN=Thawte Personal Freemail CA,
        OU=Certification Services Division,
        O=Thawte Consulting, L=Cape Town, S=Western Cape, C=ZA
Public Key Algorithm:
  Algorithm ObjectId: 1.2.840.113549.1.1.1
  Algorithm Parameters:
    05 00
PublicKey: UnusedBits=0
30 81 89 02 81 81 00 d4 69 d7 d4 b0 94 64 5b 71 0.....f....d[q
e9 47 d8 0c 51 b6 ea 72 91 b0 84 5e 7d 2d 0d 8f .G..Q..r...^)-..
7b 12 df 05 25 75 20 74 3a 42 2c 63 27 9f 95 7b {...%u(t:B,c'..(
4b ef 7e 19 87 1d 86 ea a3 dd b9 ce 96 64 1a c2 K.-.....d..
14 6e 44 ac 7c e6 8f e8 4d 0f 71 1f 40 38 a6 00 .nD.|...M.q.@B..
a3 87 78 f6 f9 94 86 5e ad ea c0 5e 76 eb d9 14 ..x....^....^v...
a3 5d 6e 7a 7c 0c a5 4b 55 7f 06 19 29 7f 9e 9a .]nz|..KU...)...
26 d5 6a bb 38 24 08 6a 98 c7 b1 da a3 98 91 fd &.j.8$.j.....
79 db e5 5a c4 1c b9 02 03 01 00 01 y..Z.....
Root Certificate: Subject matches Issuer
```

Subject==Issuer
therefore this is
a root CA cert

Basic PKI Model



Certificate Chaining



Certificate Revocation

- Certificate might require to be revoked (cancelled) under various scenarios:
 - Certificate expired!
 - Compromise of public-private key
 - CA might not be operating anymore
- Certificate revocation lists:
 - CA issued statement of revoked certificates
- Drawbacks with CRL:
 - Periodic updates are necessary. Possibility of race conditions leading to the use of revoked certificates.

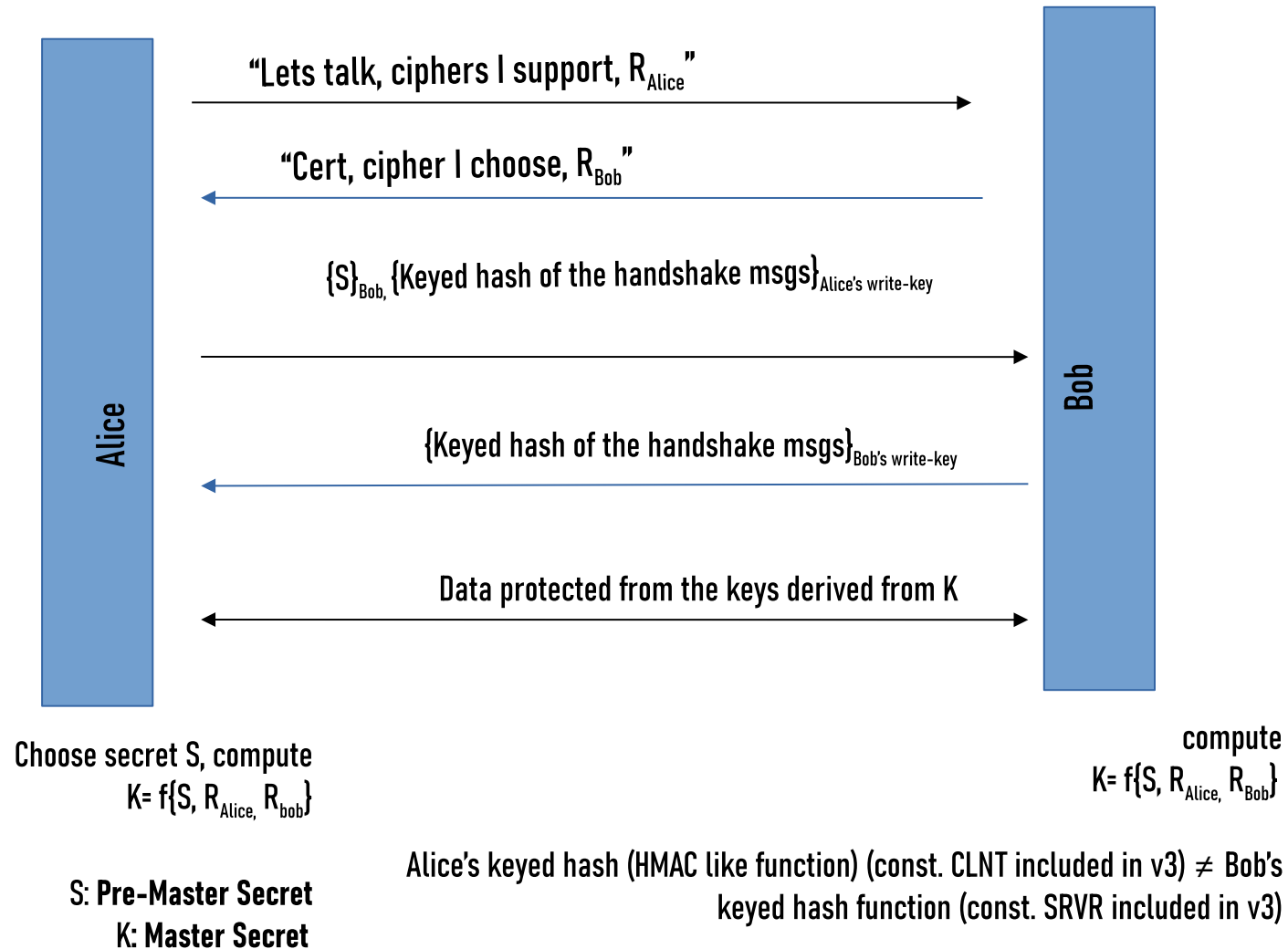
Secure Sockets Layer(SSL)/ Transport Layer Security(TLS)

- One of the most important security primitives
- used for ensuring confidentiality, authentication, integrity protection on the Internet.
- Used by most popular web based services for ensuring authentication of site, confidentiality+integrity protection of data on the fly.
- Can be used for various other purposes e.g. Tunelling and proxying applications.

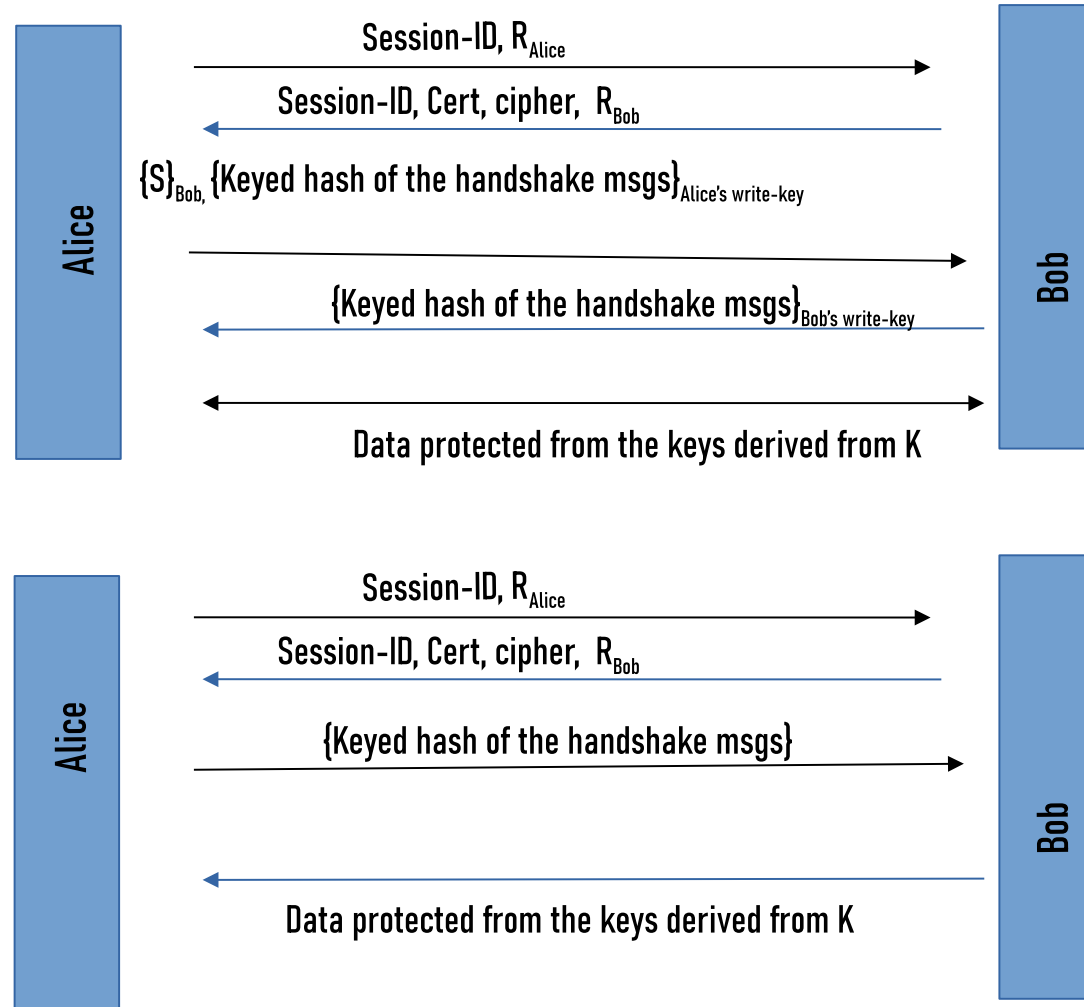
Brief History

- SSLv2 originally developed by Netscape Inc. for their browser - Netscape Navigator 1.1 in 1995.
- MS derived their own version called PCT (Private Communication Technology).
- Netscape came back with SSLv3.
- IETF came up with the overarching TLS which is not really compatible to SSLv3 but serves the same purpose with minor modifications.

(Simplified) SSL (v3)



(Simplified) SSL (v3) With Session Resumption



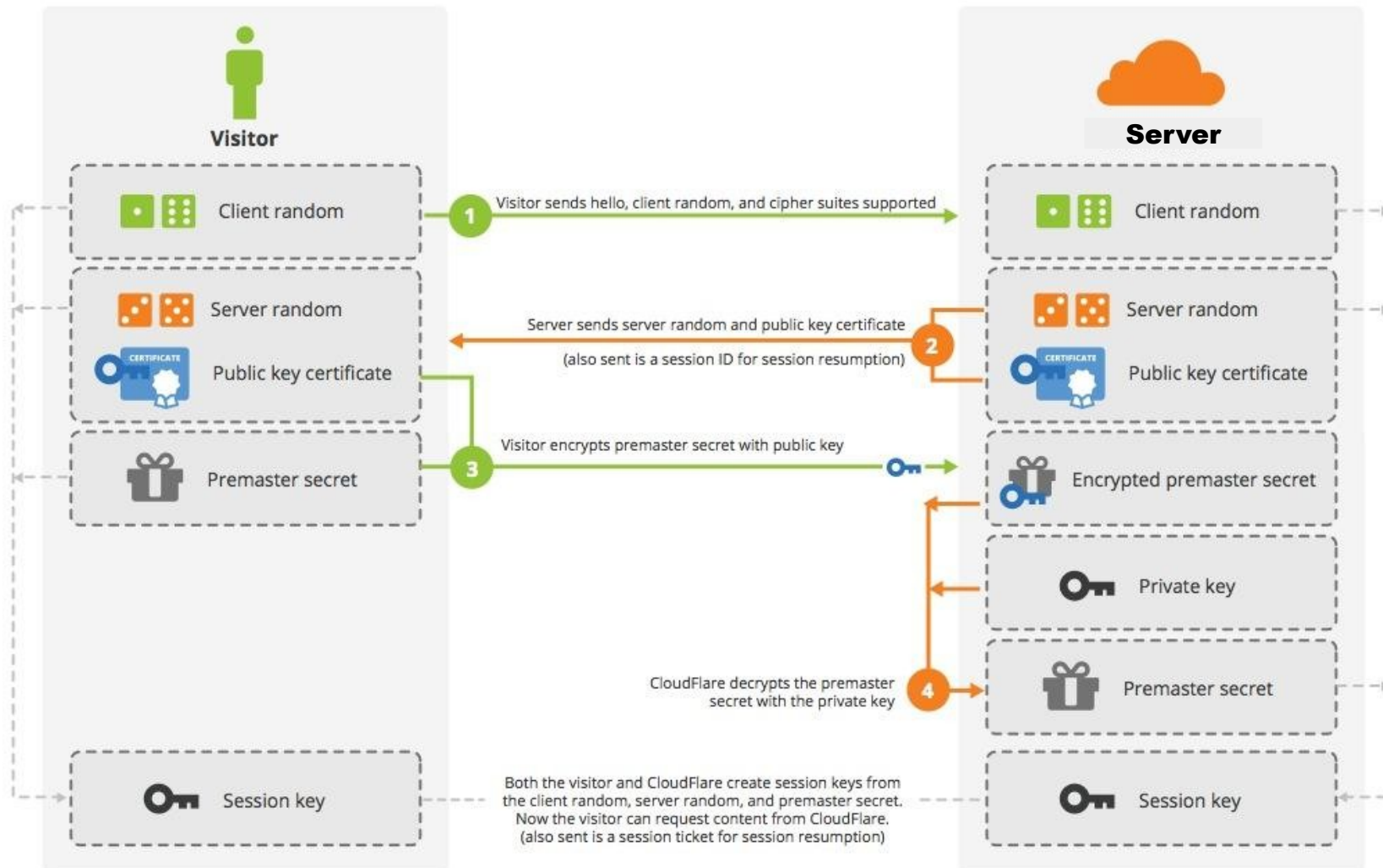
Key Establishment

- $K = \text{HKDF}\{S, R_{\text{Alice}}, R_{\text{Bob}}\}$ is actually a set of six reshuffles to produce six keys -- confidentiality, authentication+integrity protection, IV for each direction.
- In case of using RSA encryption, the client and servers use Ephemeral Diffie Hellman keys (DHE). - derived from the idea of having shorter client and server sides of DH key while the fully established key may be longer.

RSA DHE Key Establishment

SSL Handshake (RSA)

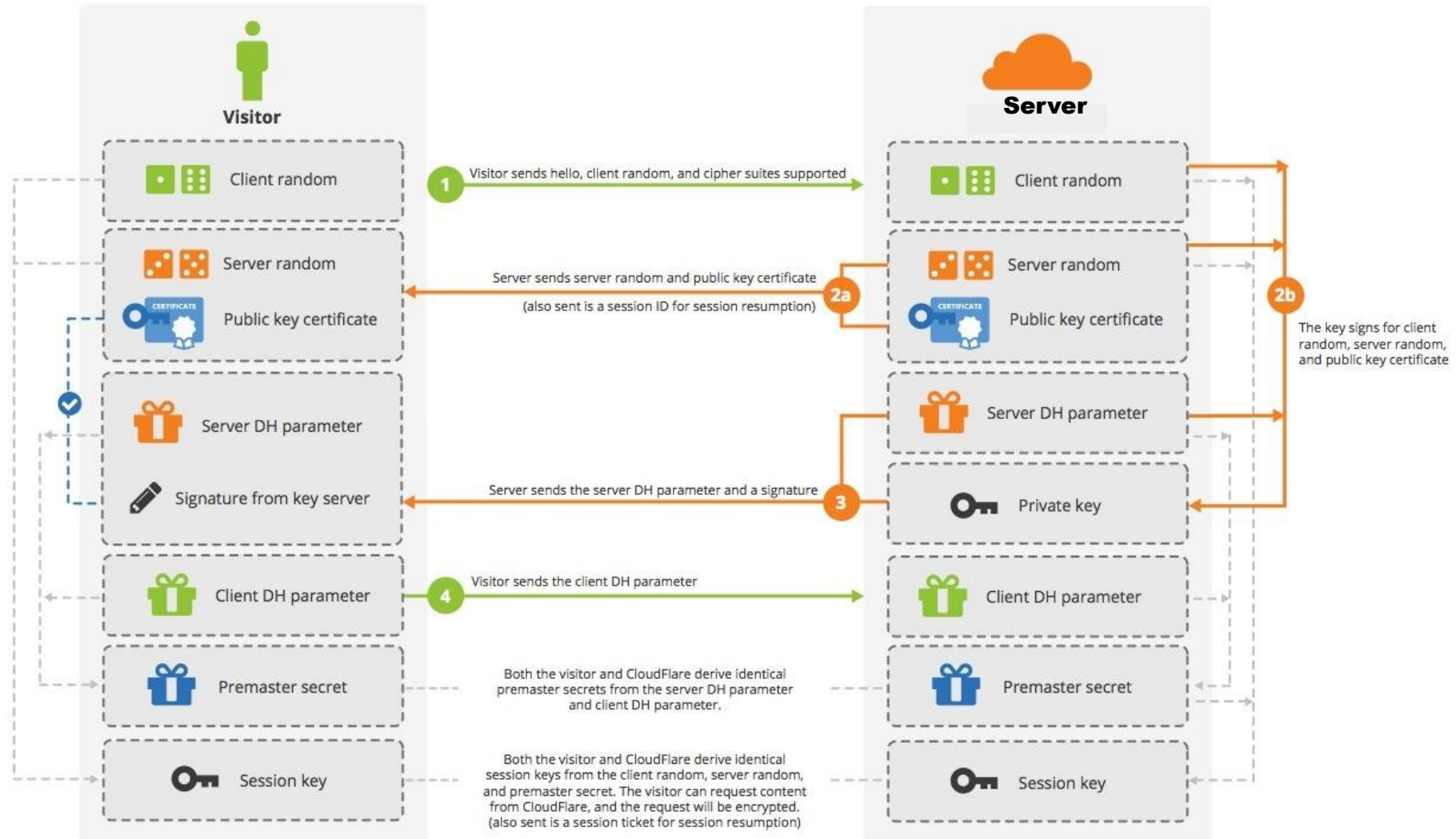
Handshake



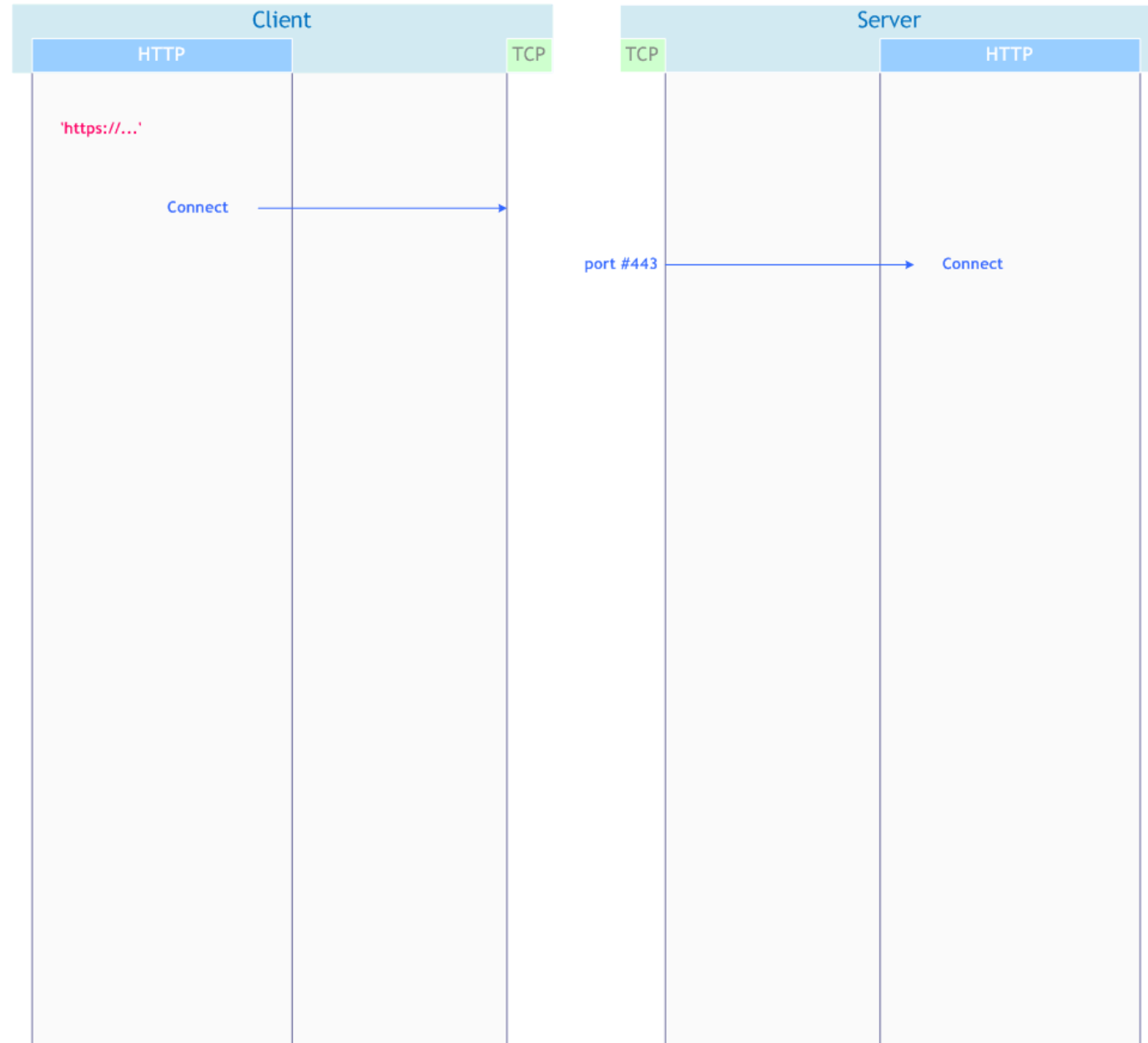
RSA DHE Key Establishment

SSL Handshake (Diffie-Hellman)

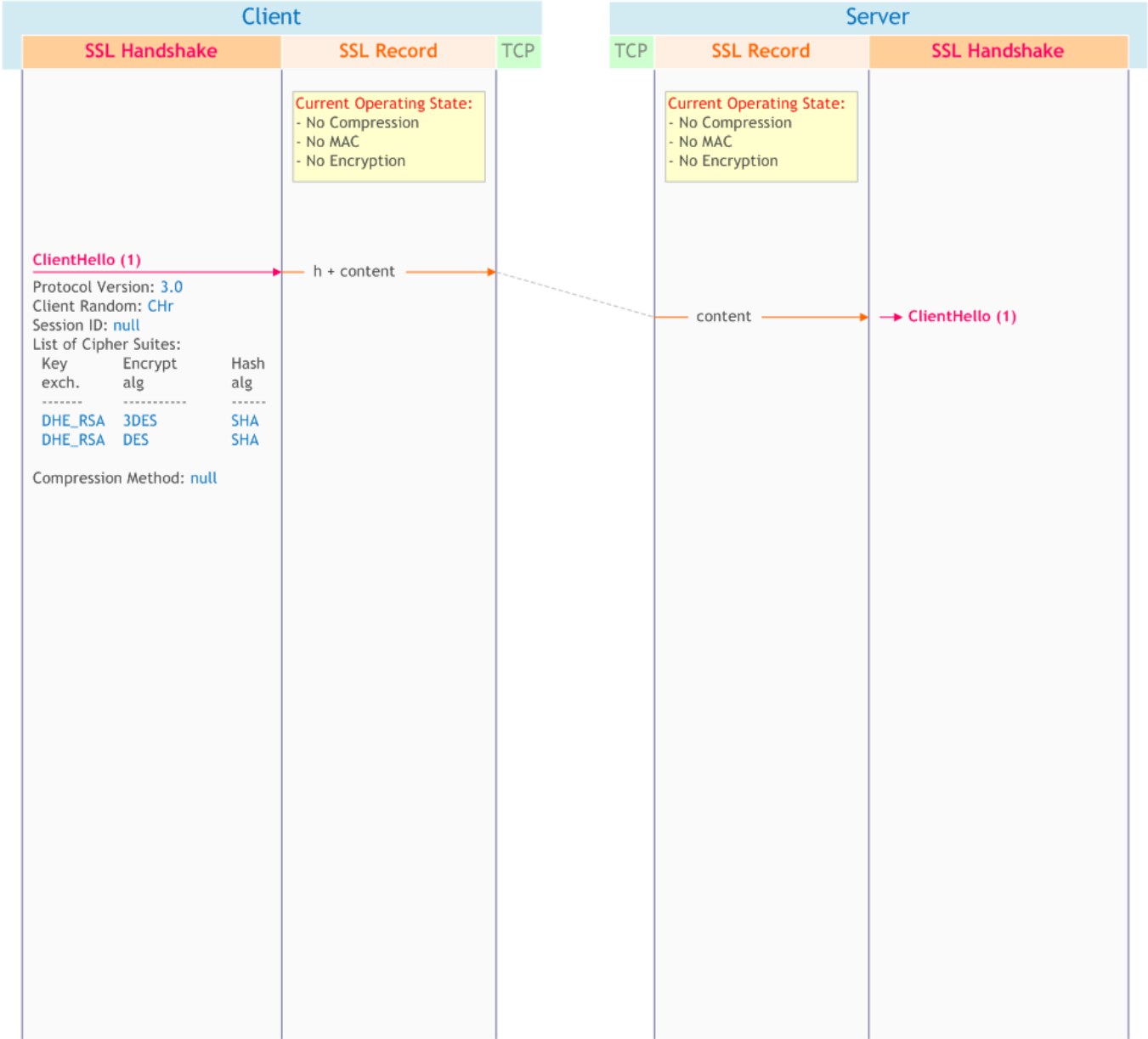
Handshake



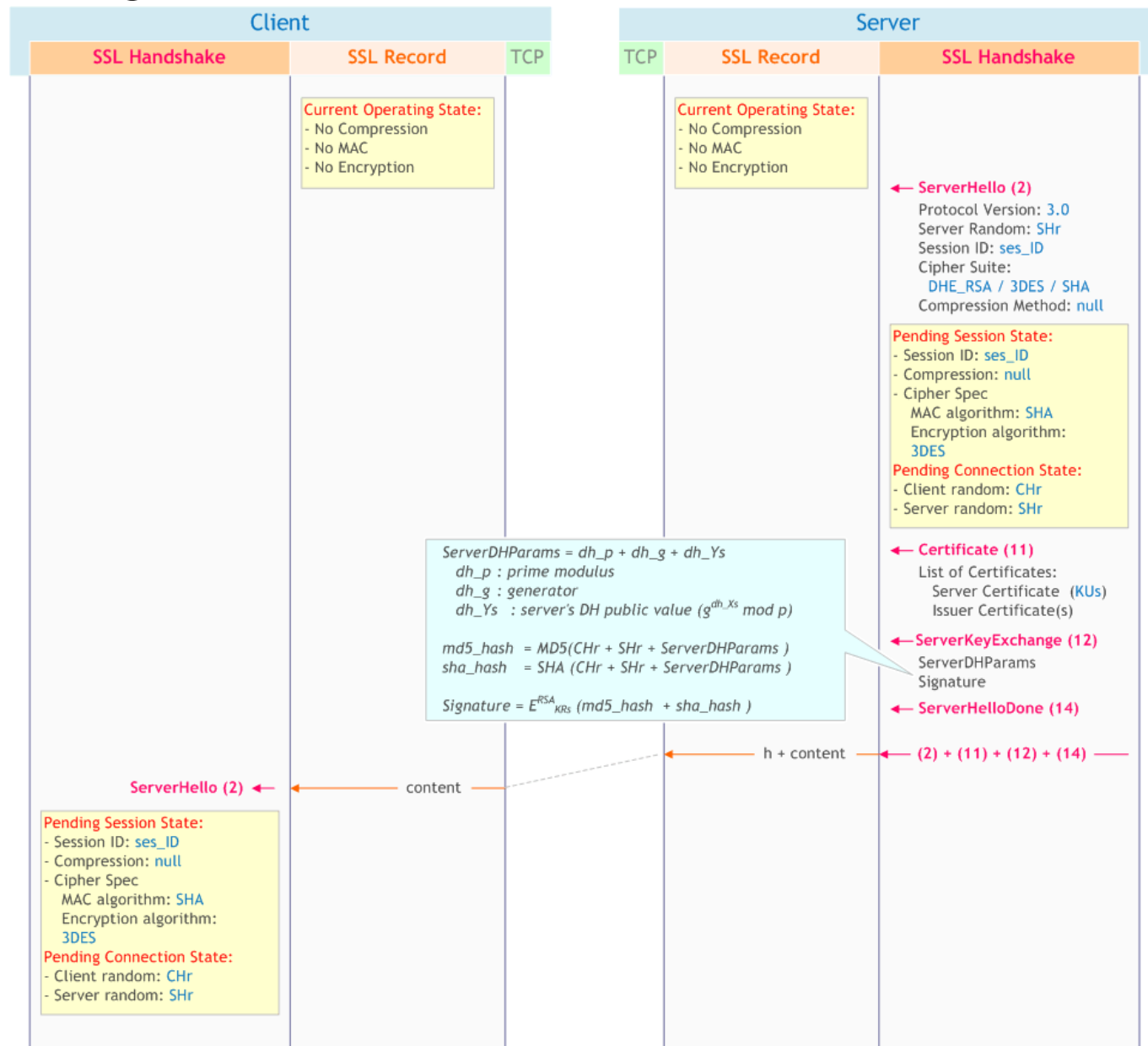
RSA DHE Key Establishment



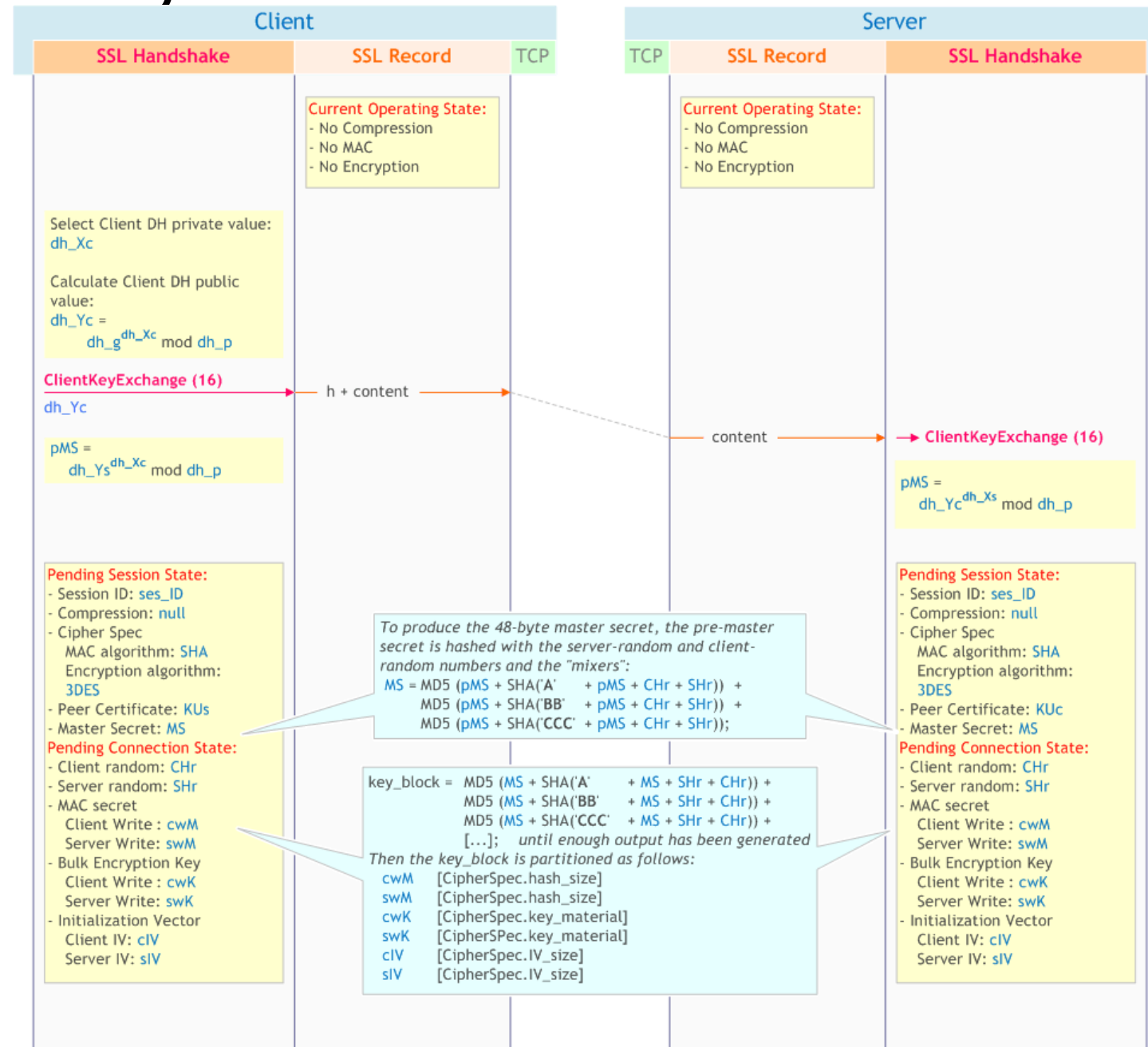
RSA DHE Key Establishment



RSA DHE Key Establishment

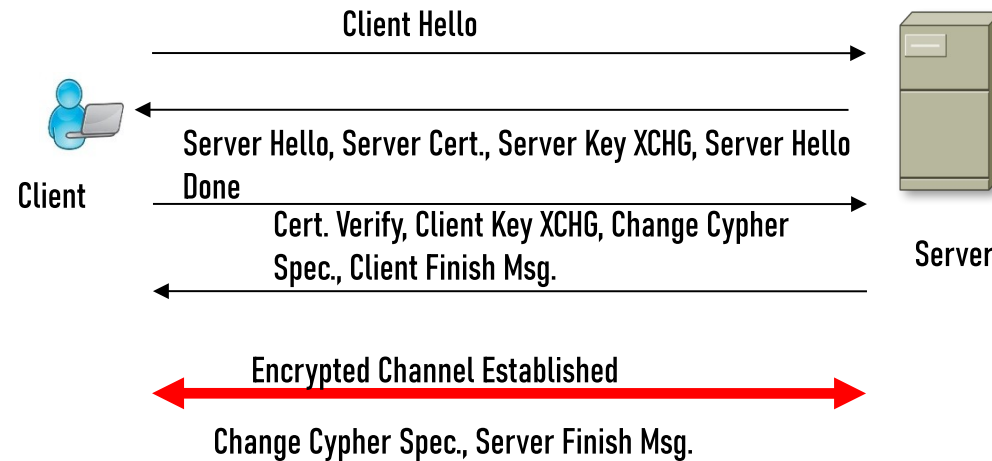


RSA DHE Key Establishment

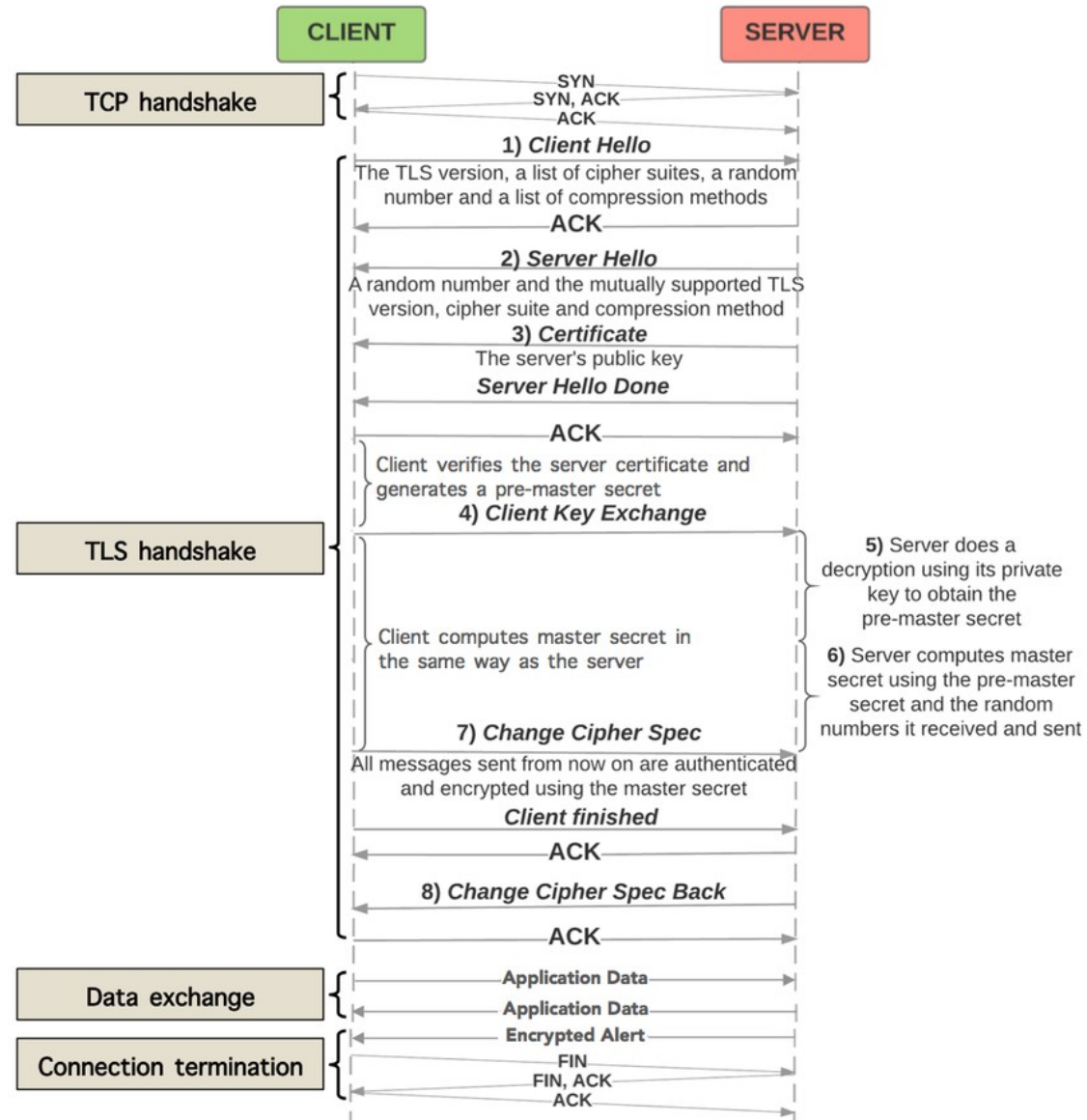


Client-Server Certificate Authentication: Basics of TLS Protocol

- Multi-step authentication, certificate and key exchange protocol.
- Client Hello --> Server
- Server Hello, My cert., Key XCHG., Client
- Client: Verify server cert.
- Client Key XCHG, My enc. algos. server
- Server Lets choose algo. A server
- Client encrypted channel server



Basic TLS v 1.2 Protocol



TLS 1.2 handshake full/abbreviated

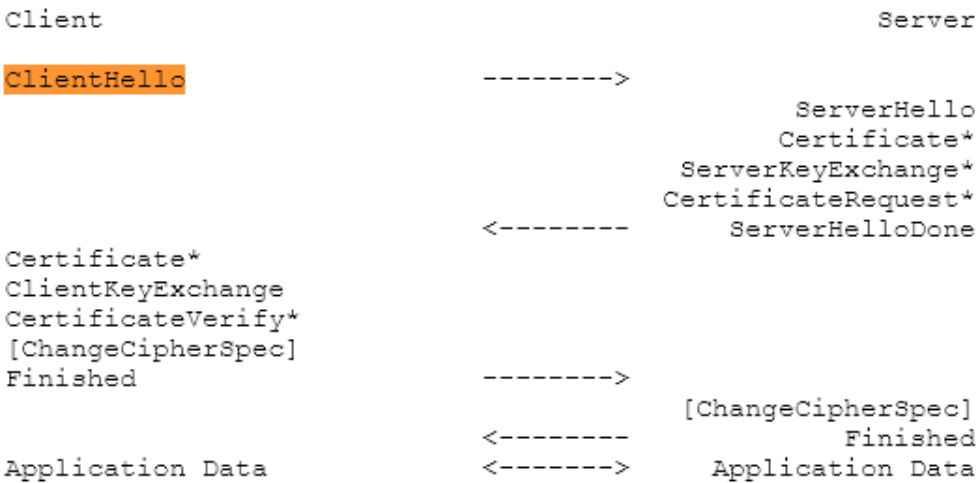


Figure 1. Message flow for a full handshake

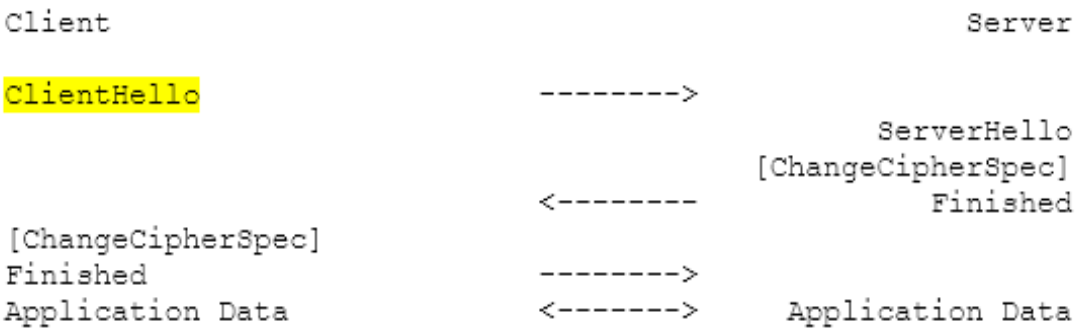


Figure 2. Message flow for an abbreviated handshake

Wildcard certs. and SNI.

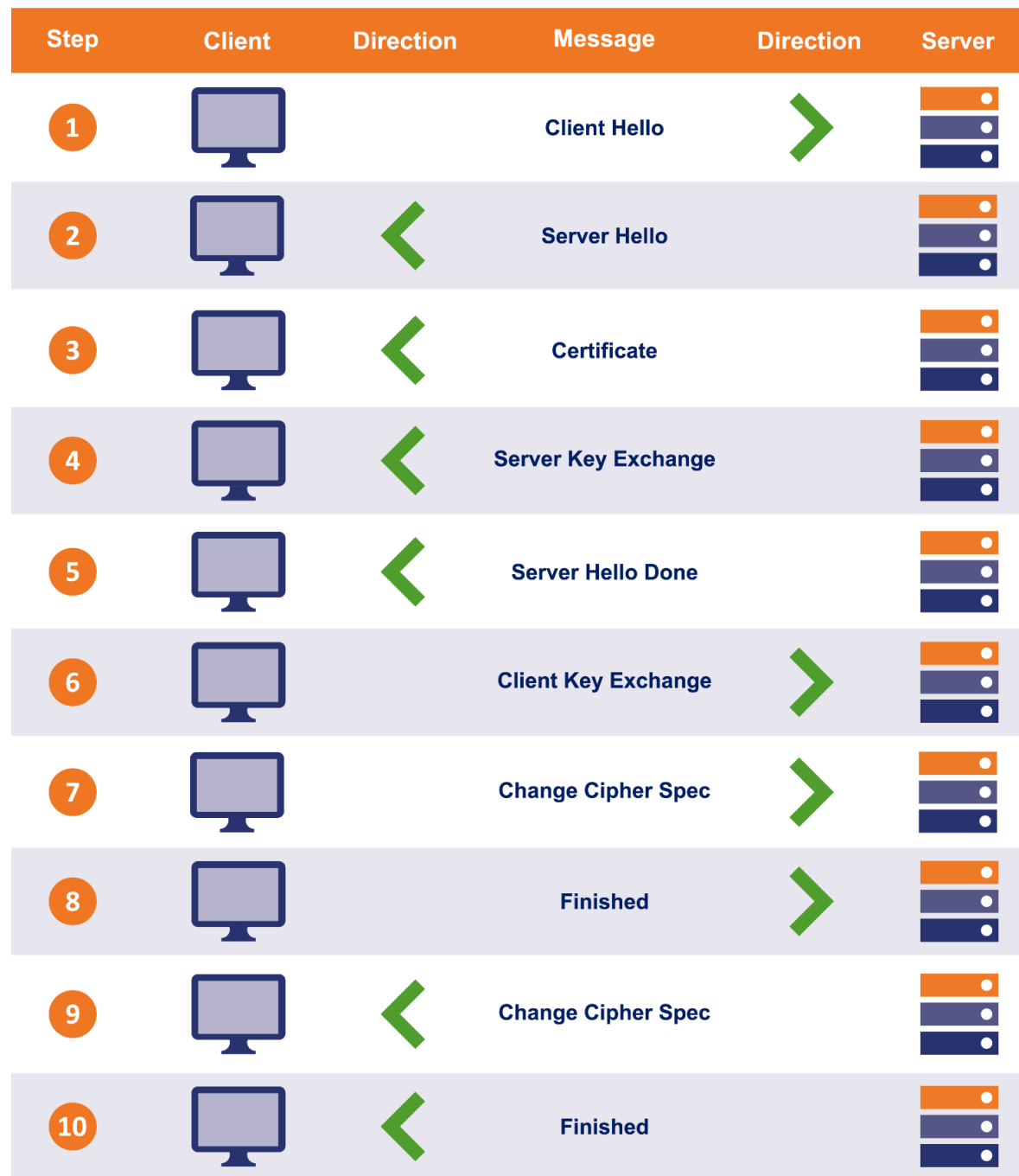
- SNI: Server name identifier.
- SNI == domain name. Especially needed in multi-hosting scenarios.
- Wildcard certs: SNI: *.iiitd.ac.in , *.google.com

Problems with SNI: Reveals domain be communicated.

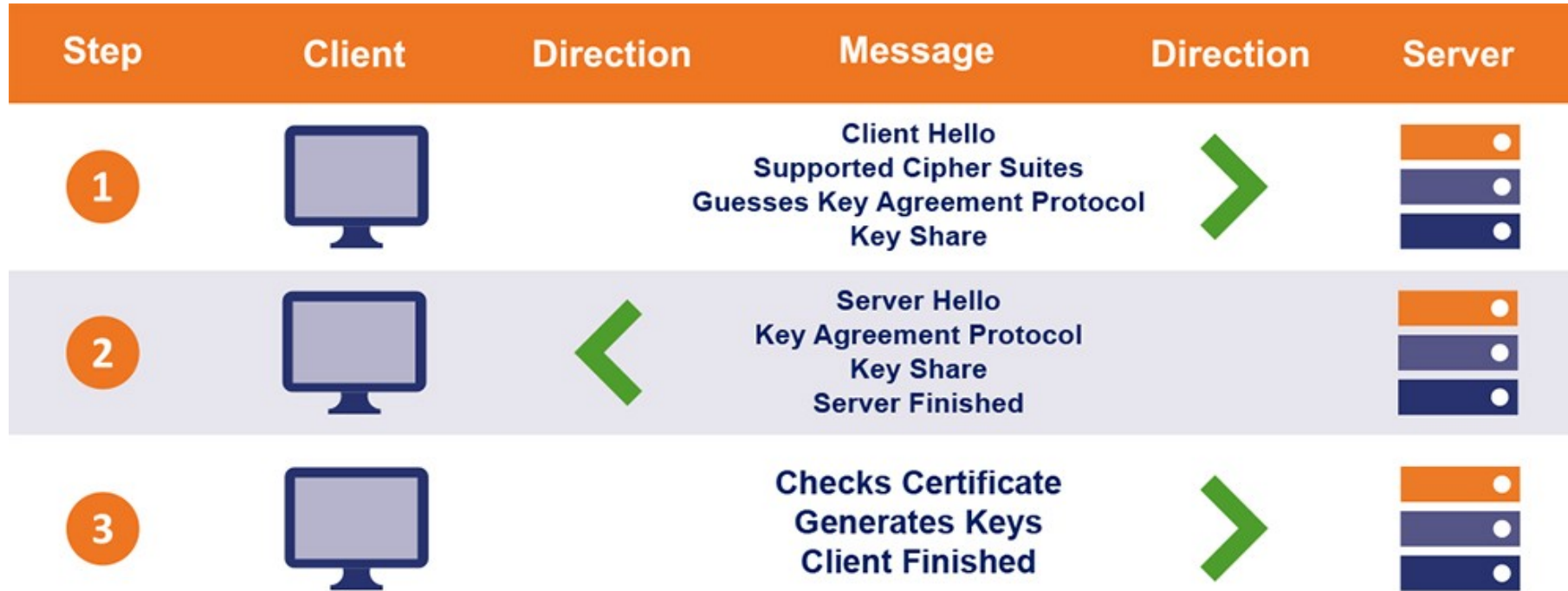
TLS v1.2

VS

TLS v1.3



TLS v1.2 vs TLS v1.3



TLS 1.3 - Key differences

- No support for older insecure ciphers.
- ONLY Ephemeral DH key exchange (no public/private key pair).
- *No support for non-PFS key exchange mode.*
- Geared towards privacy - Encrypted cert., encrypted SNI.
- ~~Zero RTT session resumption~~ (No PFS).
- Not compatible with TLS 1.2.
- **ESNI**/ECH: Encrypt the SNI / identifier information.

TLS 1.3 handshake (1-RTT)

Rescorla

Standards Track

[Page 15]

RFC 8446

TLS

August 2018



Figure 3: Message Flow for Resumption and PSK

TLS 1.3 handshake (0-RTT)

RFC 8446

TLS

August 2018

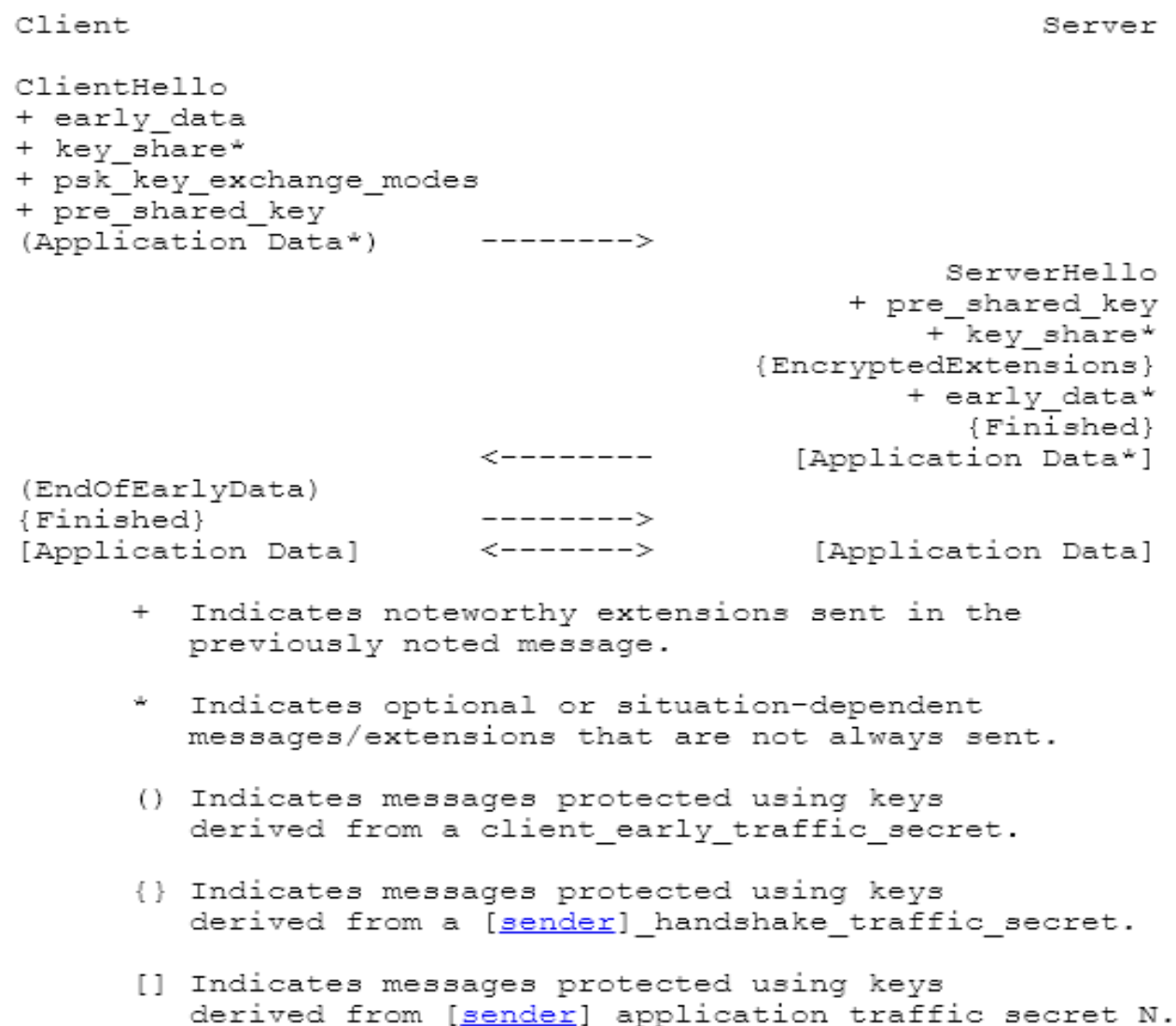


Figure 4: Message Flow for a 0-RTT Handshake

ESNI/ECH

ESNI: SNI Encrypted with the domain specific ESNI key.

Initially implemented by Cloudflare.

Query for DNS TXT record for `_esni.(domain-name).(extension)`.

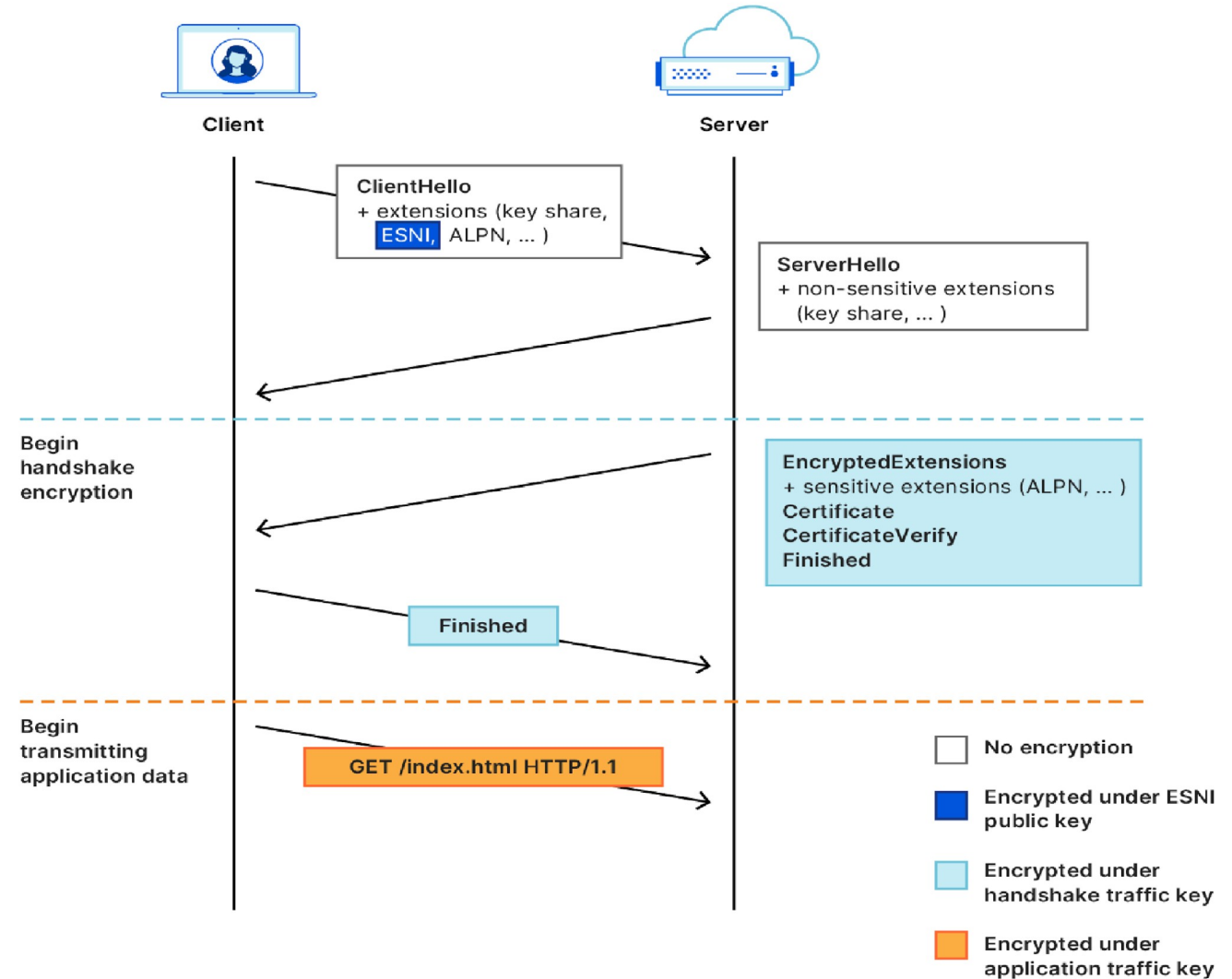
Available for most Cloudflare domains.

Deprecated for ECH

ESNI (Now deprecated)

Reasons:

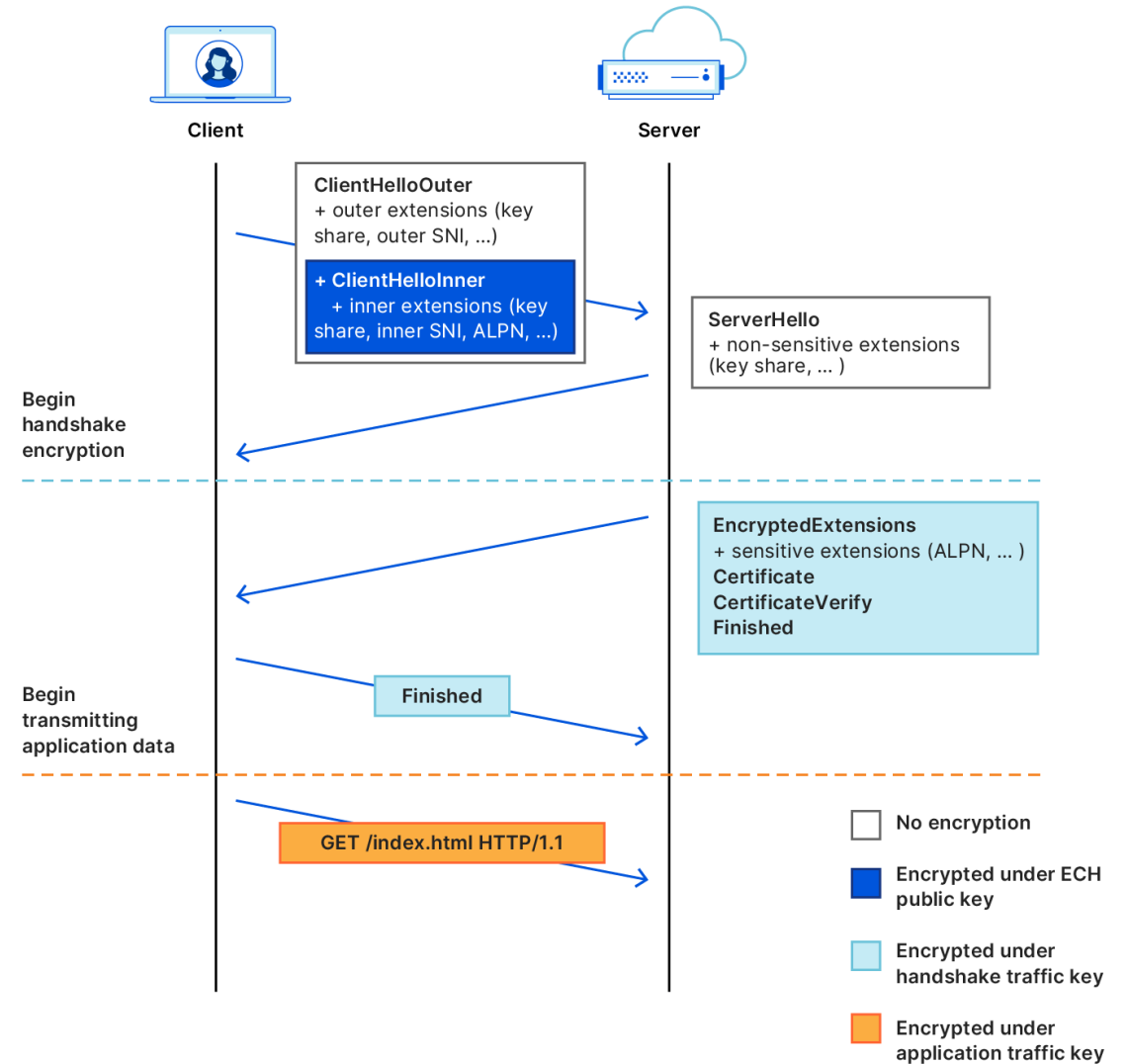
- TLS extensions, ALPN, ciphersuites etc. unencrypted. May be used for fingerprinting.



ECH (Encrypted Client Hello)

Inner: Most of the identification information is now in the inner header (encrypted)

Outer: Not used; left for backward compatibility with ESNI.



DNS over HTTPS / DNS over TLS

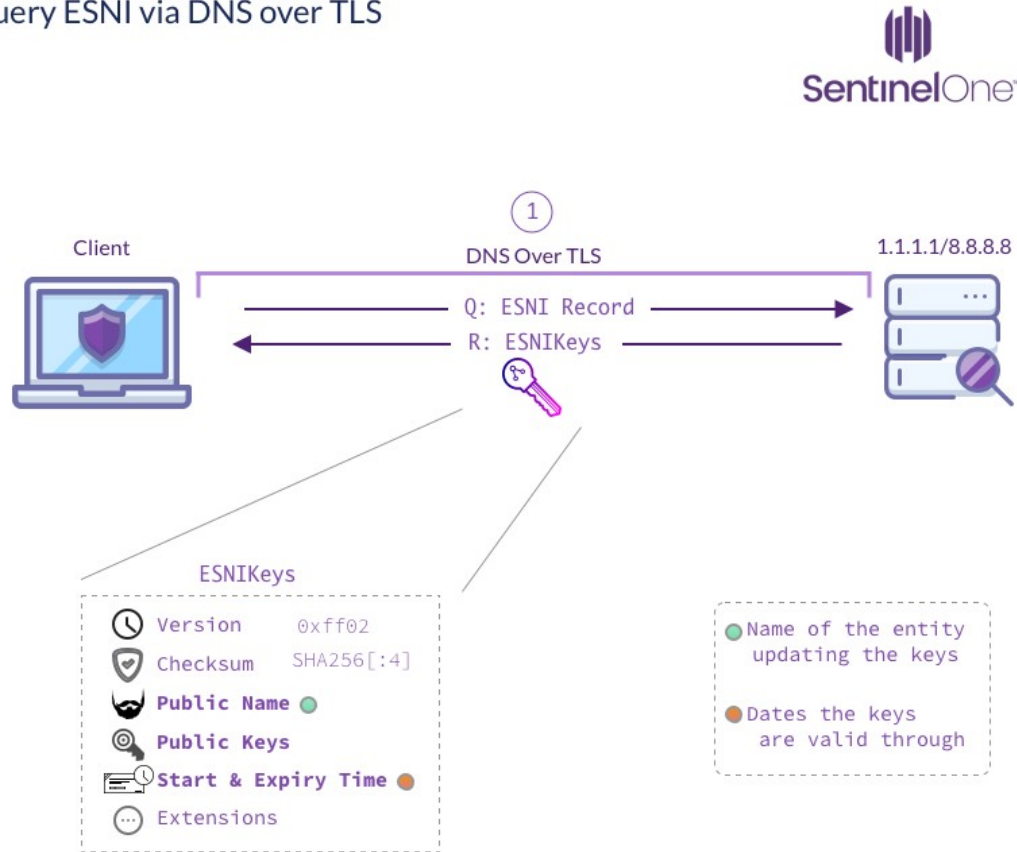
DNS TXT records may be dropped by the adversary.

What if DNS query is itself encrypted!

Send DNS via a HTTPS (or TLS/TCP/IP connection).

DNS over HTTPS / DNS over TLS

Query ESNI via DNS over TLS



Spec Version: IETF eSNI [DRAFT 3](#)



Creating the *Encrypted SNI*

Public Keys (from ESNIKeys)

ffdhe8192 ^{1,1} (DHE)	Pub (Y)	} KeyShareEntry ¹
x25519 (ECDHE)	Pub (Y)	
secp521r1 (ECDHE)	Pub (Y)	

2 Client chooses (EC)DHE group

3 Derive Shared Key



A = Client Generated Secret
Y = Public Key from chosen KeyShareEntry
P = Group Modulus from chosen KeyShareEntry

$$\text{Secret_Key}_2 = Y^A \bmod P$$

Also: Prepare our Key Share with our Public Key so that the server can also derive the shared secret key, it is also sent during ClientHello

4 Prepare ClientESNIInner

5 Encrypt ClientESNIInner

ClientESNIInner

Nonce 16 Bytes
SNI List

5 AEAD-Encrypt Using Secret_key

Encrypted SNI

1 [RFC 8446 The Transport Layer Security \(TLS\) Protocol Version 1.3](#)

1.1 Supported Group Extension - Section 3.1.4

2 ECDHE calculation is (a bit) different

Spec Version: IETF eSNI [DRAFT 3](#)



DNS over HTTPS / DNS over TLS

Catch 22 situation:

DoT easily identifiable by IP and/or port.

Resolvers do not change dynamically.

DoH requires DNS to identify the DoH server.

QUIC

Objective: Reduced connection establishment/setup latency. *Secure*, performance improvements over vanilla TCP.

Reality:

- UDP/IP with application layer flow/congestion control, delivery order etc. (instead of what happens for TCP in the OS kernel).

- TCP-like handshake; includes TLS 1.3 handshake as well.

- Effectively: {TLS / TCP (app layer)} / UDP / IP

- 1-RTT handshake: TCP 3-way handshake with TLS 1.3 handshake together.

- 0-RTT handshake: Same as TLS 1.3. 0-RTT. No FS.